

INDEPENDENT AUDIT REPORT

Akemi Tattoo SEO and Security Audit

Prepared for the public website at akemiontattoo.vercel.app

AUDIT DATE March 24, 2026	SCOPE Live public pages, headers, metadata, and exposed public endpoints	STATUS Assessment only. No fixes applied.
-------------------------------------	--	---

The site has a solid baseline transport setup: HTTPS redirect, HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, and Permissions-Policy are present. The main gaps are SEO fundamentals, content quality, metadata completeness, and a few hardening improvements around CSP and public write endpoints.

Executive Summary

Priority	Theme	Main Problem	Recommended Direction
High	Crawlability	robots.txt and sitemap.xml return 404	Add crawler guidance and generate an indexable sitemap
High	Metadata	Homepage and gallery pages reuse the same core metadata	Create route-specific title, description, and canonical tags
Medium	Content Quality	Placeholder-like text is live on public pages	Replace with polished, descriptive, location-aware copy
Medium	Social SEO	No Open Graph, Twitter Card, or structured data	Add social metadata and JSON-LD
Low	Security Hardening	CSP is present but permissive	Tighten sources and remove inline allowances over time

Detailed Findings And Improvement Guidance

HIGH PRIORITY

1. Missing crawl discovery endpoints

Observation: Both `/robots.txt` and `/sitemap.xml` return 404.

Why it matters: Search engines have no explicit crawl map or sitemap hint for the homepage, galleries, and future content pages.

How to improve:

- Add a public `robots.txt` file that allows crawling of public content and points to the sitemap URL.
- Generate a real XML sitemap containing every indexable route, including the homepage, gallery pages, and post pages.
- Update the sitemap automatically whenever a new gallery or post becomes public.

HIGH PRIORITY

2. Duplicate metadata across public routes

Observation: The homepage and gallery pages present the same core page title and description instead of route-specific metadata.

Why it matters: Search results become repetitive, weaker pages compete with each other, and gallery pages lose the chance to rank for their own styles or themes.

How to improve:

- Assign every public route its own title, description, and canonical.
- For gallery pages, include the gallery name, tattoo style, artist name, and city in the metadata.
- Keep titles distinct and concise, ideally centered around service + artist + location.

HIGH PRIORITY

3. Meta descriptions are brand-forward but search-light

Observation: The public description focuses on the site being "built for Vercel + Supabase" rather than client-facing search intent.

Why it matters: Technical stack language does not help attract tattoo clients and uses valuable metadata space for information users do not search for.

How to improve:

- Rewrite descriptions around what a potential client would search for: Berlin tattoo artist, blackwork, fine line, custom tattoo booking, private studio.
- Make the homepage description service-oriented and gallery descriptions style-oriented.
- Keep descriptions readable and specific rather than keyword-stuffed.

MEDIUM PRIORITY

4. Canonical tags are missing

Observation: Canonical URLs were not present on the live pages reviewed.

Why it matters: Canonicals help search engines understand the preferred URL for each page and reduce ambiguity around duplicate or alternate views.

How to improve:

- Add one canonical URL per indexable route.
- Ensure canonicals always reference the public production domain.
- If a route should not rank, use `noindex` instead of giving it a ranking canonical.

MEDIUM PRIORITY

5. Social sharing metadata is absent

Observation: No Open Graph or Twitter Card metadata was found on the reviewed pages.

Why it matters: Shared links will have weaker previews and less control over title, description, and image appearance.

How to improve:

- Add `og:title`, `og:description`, `og:url`, and `og:image` tags.
- Add a `twitter:card` tag, usually a large summary card for portfolio sharing.
- Create one branded preview image template for homepage shares and one adaptable template for galleries.

MEDIUM PRIORITY

6. Structured data is missing

Observation: No JSON-LD structured data was visible in the live markup reviewed.

Why it matters: Search engines receive less explicit information about the artist, business context, location, and booking intent.

How to improve:

- Add JSON-LD for a `Person` or `LocalBusiness` style entity, depending on how the brand is positioned.
- Include artist name, city, site URL, contact or booking URL, service type, and public social profiles if available.
- Add route-level structured data to gallery pages only if the content is unique enough to justify it.

MEDIUM PRIORITY

7. Public content contains placeholder or low-trust copy

Observation: Strings such as asdasadasdasdasdsadsa, :;!, galeria 1, and galeria 2 appear on live pages.

Why it matters: Placeholder text lowers perceived quality, weakens keyword relevance, and can make search engines treat content as thin or unpolished.

How to improve:

- Replace all temporary text with final editorial copy before allowing indexation.
- Use gallery names that are stylistically consistent and meaningful to visitors.
- Add short, descriptive summaries that explain what each gallery or post represents.

MEDIUM PRIORITY

8. Gallery pages need stronger standalone ranking content

Observation: Gallery pages appear to function mainly as filtered or repeated portfolio views.

Why it matters: Thin pages rarely rank well without a distinct headline, intro copy, and page-specific metadata.

How to improve:

- Give each gallery page a unique intro paragraph that explains style, subject matter, and fit for prospective clients.
- Add one clear H1 per gallery page that differs from the homepage framing.
- Consider adding a short FAQ or booking CTA section tailored to the gallery style.

MEDIUM PRIORITY

9. Image delivery is not fully optimized

Observation: The site uses plain `<img>` tags without explicit dimensions, and one image URL points to a Getty search-results page rather than a stable media asset.

Why it matters: This can hurt layout stability, performance, maintainability, and image indexing quality.

How to improve:

- Use stable direct image assets only.
- Set explicit width and height values for public images.
- Keep alt text descriptive and specific to the visible work, not generic labels.
- Prefer responsive image optimization through the framework when practical.

LOW PRIORITY

10. Public page payload appears to include more data than necessary

Observation: The public HTML source exposes record IDs and additional fields such as created timestamps and other item metadata that may not be needed for first paint.

Why it matters: This is not a critical vulnerability, but reducing public payloads improves data minimization and can slightly reduce unnecessary exposure.

How to improve:

- Return only the fields required to render the public UI.
- Keep administrative, internal, or non-essential descriptive fields out of public route payloads when they do not support rendering.
- Review public selectors whenever content models expand.

LOW PRIORITY

11. Content Security Policy is present but permissive

Observation: The current CSP includes 'unsafe-inline' for scripts and styles, and connect-src allows broad https: access.

Why it matters: The policy still provides protection, but it allows a wider execution and connection surface than necessary.

How to improve:

- Move toward nonces or hashes for inline scripts and styles where feasible.
- Restrict connect-src to only the exact domains required by the app.
- Roll out stricter CSP changes in report-only mode first to catch breakage safely.

LOW PRIORITY

12. Stack fingerprinting can be reduced

Observation: The live response exposes X-Powered-By: Next.js and Server: Vercel.

Why it matters: This is not a direct vulnerability, but reducing unnecessary fingerprinting is a reasonable hardening practice.

How to improve:

- Disable the framework-powered-by header where supported.
- Treat this as a cleanup task rather than a primary risk item.

MEDIUM PRIORITY

13. Abuse protection should be consistent across public write endpoints

Observation: Public client code references booking, contact, and payment endpoints. Invalid payloads were rejected and rate limiting was observed on the contact endpoint after repeated bad requests.

Why it matters: Public forms and payment initiators are common spam and abuse targets even when they are not fully exploitable.

How to improve:

- Apply consistent rate limiting to all public write endpoints, not just selected ones.
- Add a bot-friction control such as a honeypot field or a CAPTCHA alternative like Turnstile.
- Monitor repeated failures, bursts, and abnormal geographies in logs.

MEDIUM PRIORITY

14. Multilingual SEO appears limited to cookie-based switching

Observation: The public interface offers EN, ES, and DE language buttons, but the behavior appears to rely on a locale cookie and page reload rather than separate language URLs. This is an inference from client behavior and public source.

Why it matters: Search engines usually need stable language-specific URLs and hreflang signals to index multilingual variants effectively.

How to improve:

- If multilingual SEO matters, expose language-specific routes such as path-based or subpath-based variants.
- Add hreflang annotations between language versions.
- If multilingual indexing is not a goal yet, keep only one public language version indexable until localization is complete.

LOW PRIORITY

15. Locale cookie can be made more production-consistent

Observation: The public locale cookie appears to be set client-side with SameSite=Lax. Because it is client-written, it cannot be HttpOnly, but it can still be treated more strictly.

Why it matters: This is a low-risk preference because the cookie appears to be non-sensitive, but production cookie hygiene is worth standardizing.

How to improve:

- Add the Secure attribute when writing the cookie in production over HTTPS.
- If locale handling moves server-side later, consider centralizing cookie policy there.

What Already Looks Good

- HTTP requests redirect to HTTPS using a permanent 308 redirect.
- Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, and Permissions-Policy are present.
- No obvious client-side secrets or API keys were found in the public HTML reviewed.
- Invalid form payloads for booking and contact were rejected with 400 responses.
- Rate limiting was observed on the contact endpoint after repeated bad requests, which indicates at least some abuse protection exists today.

Recommended Implementation Order

Phase	Focus	Recommended Work
Phase 1	Indexing basics	Add robots.txt, generate sitemap.xml, and define unique page metadata and canonicals.
Phase 2	Content quality	Replace placeholder text, strengthen gallery copy, and improve descriptions for client search intent.
Phase 3	Rich search presentation	Add Open Graph, Twitter Card metadata, and JSON-LD structured data.
Phase 4	Performance and resilience	Improve image delivery, reduce unnecessary payload data, and review multilingual URL strategy.
Phase 5	Security hardening	Tighten CSP, standardize endpoint abuse protection, and reduce unnecessary stack disclosure.

Audit Sources

- Homepage
- Gallery route
- robots.txt
- sitemap.xml

This report reflects the live site behavior observed on March 24, 2026. It is an implementation guidance document only. No code, content, or infrastructure changes were made as part of this audit.